

Sovereignty Is a Risk Decision

A summary for boards and executive committees. Roger Halbheer, Field CISO, Microsoft. September 2026.

One disclosure first, because it is the cheapest attack on this argument. I work for Microsoft. An argument that you should spend less on jurisdictional independence and more on security operations happens to suit my employer. So weigh the evidence, not the author. Every figure below is sourced, and the most serious case I cite is an intrusion against my own company. ¹

The decision in front of you

Sovereignty is a risk decision, and the unit of decision is the workload, not the company. There is no organization-wide sovereignty posture worth having. Your public website and your one workload that genuinely cannot leave deserve different answers. **The most expensive mistake available here is to decide once and apply it everywhere.**

Four things the board should hold

1. Two risks sit in this debate, and only one of them can be measured.

The first is ordinary compromise. Average time from an attacker's first access to lateral movement was twenty-nine minutes in 2025, and the fastest ever observed was twenty-seven seconds. ² The median handoff to a second criminal group fell to twenty-two seconds, from more than eight hours in 2022. ³ ENISA recorded 4,875 incidents in the year to 30 June 2025, with public administration the most targeted sector in the Union at 38.2 percent. ⁴

The second is foreign lawful access to your data. **As of September 2026 there is no publicly documented case of a CLOUD Act order against a named European enterprise or government cloud customer.** ⁵ I read that risk as very unlikely. I also cannot quantify it, and neither can anyone else: the secrecy regimes make confirmation unlawful, so the absence of cases has two honest readings and I carry both.

An environment an ordinary attacker already occupies is not a sovereign environment, whatever the contract says. Security is a precondition of sovereignty, not a parallel program.

2. These laws exist for a reason we endorse.

Democracies pass compelled-access powers so law enforcement can pursue terrorism, child abuse and human trafficking. **The instrument usually named in this debate is the United States CLOUD Act of 2018,** which requires a provider subject to US jurisdiction to produce data in its possession, custody or control regardless of where that data is stored. ⁶ **The United States is not alone in holding such powers, and the examples below are examples and not a survey.** Countries like the United Kingdom, France, Switzerland and China hold comparable instruments, and the European Union has built one of its own in the e-Evidence Regulation. ^{7 8 9 10} **The question is not whether such powers should exist. It is how much you should pay to move a given workload further from them.**

3. The price is paid in three currencies, and most organizations count one.

Money is counted. **Security speed**, meaning how fast you detect, decide and act while an attacker is inside, is rarely counted. **People are never counted and cannot be bought around**: 33 percent of organizations report no budget to staff their security teams adequately, and 29 percent cannot afford people with the skills they need.¹¹ A self-operated sovereign estate is a permanent second staffing commitment in that market.

The good news is that the cost of control is not a straight line, and the useful part of it is already built. Major cloud providers now ship a substantial body of sovereignty technology as part of the platform: data residency commitments, customer-managed and customer-held encryption keys, approval gates on support access, confidential computing that keeps data encrypted while it is being processed, and EU-operated deployment options.¹² **Most of that is configuration and licensing rather than re-platforming, and it is where most of the available sovereignty actually lives.** Take it broadly.

What is genuinely expensive is the far end: disconnected, customer-operated environments with their own headcount and a permanent loss of platform capability. **Reserve that for the few workloads that truly cannot survive without it**, and be explicit that you are buying it with capability and people, not only with money.

4. Full independence is not purchasable at any sensible price.

Take one example, and note that it is one of several. The public internet's naming system rests on thirteen root server authorities. Ten are operated by United States organizations and two in Europe.¹³ Nobody procured that layer and nobody can exit it. **The same shape appears elsewhere**: in semiconductor supply, where Europe's own auditors judged the EU's chip strategy unlikely to meet its targets,¹⁴ and in the code-hosting and developer platforms your engineering depends on, which are themselves subject to export-control regimes.¹⁵

This is concentration risk, which a board already knows how to reason about. The honest goal is not independence. It is knowing which dependencies you have accepted, deliberately, and writing them down.

The uncomfortable one

A control you have never exercised is not a control. It is a line item.

Germany's federal security authority reported that 92 percent of roughly 33,000 internet-exposed German Exchange servers were still running an out-of-support version.¹⁶ Of those, the national CERT could observe **nine** with the paid extended security updates actually installed.¹⁷ **Not nine percent. Nine servers.** Self-operation is a commitment, not a purchase, and it is routinely underestimated at the moment the decision is made.

What I would ask management for

Three named workloads, one page each. Which specific exposure is being reduced, what it costs in money, people and speed, and how you would prove it works. **If the third box cannot be filled, nothing has been bought.**

The clause in writing, from every provider on the shortlist. What they commit to contest, in which contract, what they will tell you and when.¹⁸ Compare the text, not the press release.

The measurable risk funded first. Identity hygiene, retirement of legacy authentication, governance of machine and agent identities, and the ability to detect and respond inside the window above. None of that is a sovereignty program. All of it is a precondition for one.

Written triggers, with a review date. Sequencing is only sequencing if the trigger is written down in advance; otherwise it is permanent deferral. Reasonable triggers are a change in the legal instruments that removes a provider's discretion to contest an order, a documented case affecting an organization like yours, a new regulatory obligation, or a workload moving into the must-run class.

One exercise this year, if only one. Restore a critical workload onto the infrastructure you would actually have after an incident, and see whether it comes back.

The test

The test of a sovereignty strategy is not whether it sounds sovereign. It is whether, for every critical workload, management can say which risk was accepted, which was reduced, what it cost in money, people and speed, and when it was last proved to work. **Without that, there is no strategy. There is a slogan.**

These are engineering and risk-sequencing recommendations, not legal advice. Whether a regulation requires residency for a given workload is a question for counsel, and the answer differs by sector and member state. If you want a structured estimate of foreign lawful access risk rather than an argument about it, a documented method exists and is free. ¹⁹

The full argument, with every case and every caveat, is in the companion paper "Sovereignty Is a Risk Decision". The implementation mechanics are in "Digital Sovereignty In Practice".

Notes

1. US Cyber Safety Review Board, Review of the Summer 2023 Microsoft Exchange Online Intrusion, 2024, published via CISA. <https://www.cisa.gov/resources-tools/resources/CSRB-Review-Summer-2023-MEO-Intrusion> - the Board was critical of Microsoft's security culture. Note that the Board's members were removed in January 2025, so this mechanism cannot be assumed to recur. [↗](#)
2. CrowdStrike, 2026 Global Threat Report findings, 24 February 2026. <https://www.crowdstrike.com/en-us/blog/crowdstrike-2026-global-threat-report-findings/> - breakout time is CrowdStrike's own measure over its own telemetry, vendor-defined and not independently audited. [↗](#)
3. Mandiant / Google Cloud, M-Trends 2026, 23 March 2026. <https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2026/> - vendor-defined and not independently audited. [↗](#)
4. ENISA, Threat Landscape 2025, 1 October 2025. <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025> [↗](#)
5. Microsoft, Government Requests for Customer Data report, July to December 2025. <https://www.microsoft.com/en-us/corporate-responsibility/reports/government-requests/customer-data> - self-declared and not externally audited. The report records content data provided to US law enforcement for three non-US enterprise customers with data stored outside the US, one of them in the EU or EFTA. Check for a later reporting period before publication. [↗](#)
6. Clarifying Lawful Overseas Use of Data Act, enacted March 2018. US Department of Justice CLOUD Act resources page, <https://www.justice.gov/criminal/cloud-act-resources> and the full text hosted there, https://www.justice.gov/d9/pages/attachments/2019/04/09/cloud_act.pdf - the operative provision is the new 18 U.S.C. 2713, requiring preservation and disclosure "regardless of whether such communication, record, or other information is located within or outside of the United States." [↗](#)
7. Investigatory Powers Act 2016 (United Kingdom), section 253, on technical capability notices. <https://www.legislation.gov.uk/ukpga/2016/25/section/253> [↗](#)
8. Code de la securite interieure (France), articles L871-1 to L871-7. https://www.legifrance.gouv.fr/codes/section_lc/LEGITEXT000025503132/LEGISCTA000030937362/ [↗](#)
9. Obligations that run at the holder of the decryption key rather than at the service provider: France, article 434-15-2 of the Penal Code, https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000032654251/ (version in force since 5 June 2016); United Kingdom, Regulation of Investigatory Powers Act 2000, Part III, section 49, <https://www.legislation.gov.uk/ukpga/2000/23/section/49> . Each has its own authorization requirements. Switzerland's surveillance and intelligence statutes impose cooperation duties of their own, and China's Data Security Law article 36 runs in the opposite direction, barring transfer of in-country data to foreign authorities without approval. [↗](#)

10. Regulation (EU) 2023/1543 on European Production and Preservation Orders, with Directive (EU) 2023/1544. <https://eur-lex.europa.eu/eli/reg/2023/1543/oj/eng> - it applies from 18 August 2026. [↵](#)
11. ISC2, 2025 Cybersecurity Workforce Study, 4 December 2025. <https://www.isc2.org/insights/2025/12/2025-ISC2-Cybersecurity-Workforce-Study> - global self-reported survey data from a certification body, not a European measurement. [↵](#)
12. Microsoft, What is Microsoft Sovereign Cloud?, last updated 15 July 2026. <https://learn.microsoft.com/en-us/azure/azure-sovereign-clouds/microsoft-sovereign-cloud> - Microsoft states that local and private clouds "provide the strongest sovereignty controls" but that "those environments don't deliver the full cloud value in areas such as cost-effectiveness, scalability, speed of innovation, security, and reliability." Every major provider publishes comparable sovereignty capabilities; no comparison between them is made or implied here. [↵](#)
13. Root server operators: IANA, Root Name Servers, <https://www.iana.org/domains/root/servers> - thirteen named authorities, A to M. Ten are operated by United States organizations, the WIDE Project in Japan operates M, and the two European operators are Netnod (I) and RIPE NCC (K). Root zone maintenance: ICANN, Root Zone Maintainer Agreement, <https://www.icann.org/en/stewardship-implementation/root-zone-maintainer-agreement-rzma> . Each letter is served from many physical sites worldwide via anycast, so the operator count is not a count of servers. [↵](#)
14. European Court of Auditors, Special Report 12/2025 on the EU's microchip strategy, 28 April 2025. <https://www.eca.europa.eu/en/publications?ref=SR-2025-12> [↵](#)
15. GitHub, GitHub and Trade Controls. <https://docs.github.com/en/site-policy/other-site-policies/github-and-trade-controls> [↵](#)
16. Bundesamt fuer Sicherheit in der Informationstechnik, warning on the end of support for Exchange Server 2016 and 2019, 28 October 2025. https://www.bsi.bund.de/SharedDocs/Cybersicherheitswarnungen/DE/2025/2025-287772-1032_bits.html - the 92 percent is of the approximately 33,000 German on-premises Exchange servers known to the BSI with Outlook Web Access openly reachable from the internet. It is not a count of all Exchange servers in Germany. [↵](#)
17. CERT-Bund, quoted by heise online on 31 August 2026 following heise's inquiry to the BSI: "Currently, we are only aware of 9 Exchange servers 2016/2019 in Germany on which patches released as part of ESU are installed." <https://www.heise.de/en/news/85-percent-of-on-prem-servers-in-Germany-vulnerable-11434806.html> - **CERT-Bund's figure counts servers on which ESU patches were externally observable to CERT-Bund. It is not a count of ESU enrollments.** [↵](#)
18. Microsoft, European Digital Commitments, 30 April 2025, <https://blogs.microsoft.com/on-the-issues/2025/04/30/european-digital-commitments/> - with the durable restatement at <https://learn.microsoft.com/en-us/azure/azure-sovereign-clouds/european-digital-commitments> . Microsoft's published wording governs; nothing here modifies it. Ask each provider on your shortlist for its own equivalent and compare the contract text. [↵](#)
19. David Rosenthal (VISCHER, Zurich), EU SCC Transfer Impact Assessment Toolbox. Free and author-hosted: <https://www.rosenthal.ch/downloads/Rosenthal-EU-SCC-TIA.xlsx> - a documented method, not a measurement. [↵](#)